Payment Card Industry
Estándar de Seguridad de Datos

Cuestionario de Autoevaluación A y Certificación de Conformidad

Para uso con el PCI DSS Versión 4.0.1

Revisión 1

Fecha de Publicación: Enero de 2025

DECLARACIONES: La versión en inglés del texto en este documento tal y como se encuentra en el sitio web de PCI SSC deberá considerarse, para todos los efectos, como la versión oficial de estos documentos y, si existe cualquier ambigüedad o inconsistencia entre este texto y el texto en inglés, el texto en inglés en dicha ubicación es el que prevalecerá.

Cambios en el Documento

Fecha	Versión PCI DSS	Revisión SAQ	Descripción
Octubre de 2008	1.2		Para alinear el contenido con el nuevo estándar PCI DSS v1.2 e implementar los cambios menores observados desde la v1.1 original.
Octubre de 2010	2.0		Para alinear el contenido con los nuevos requisitos y procedimientos de prueba de PCI DSS v2.0.
Febrero de 2014	3.0		Para alinear el contenido con los requisitos y procedimientos de prueba PCI DSS v3.0 e incorporar opciones de respuesta adicionales.
Abril de 2015	3.1		Actualizado para alinearse con PCI DSS v3.1. Para conocer los detalles de los cambios en PCI DSS, consulte *PCI DSS - Resumen Cambios de la Versión 3.0 a 3.1. PCI DSS.*
Julio de 2015	3.1	1.1	Se actualizó la numeración de la versión para alinearla con otros SAQ.
Abril de 2016	3.2	1.0	Actualizado para alinearse con PCI DSS v3.2. Para conocer los detalles de los cambios en PCI DSS, consulte PCI DSS - *Resumen de Cambios de la Versión 3.1 a 3.2.* Requisitos añadidos de PCI DSS v3.2 Requisitos 2, 8 y 12.
Enero de 2017	3.2	1.1	Se Actualizaron los Cambios en el Documentos para aclarar los requisitos añadidos en la actualización de abril de 2016. Se añadió una nota a la sección Antes De Empezar" para aclarar la intención de incluir los Requisitos 2 y 8 de PCI DSS.
Junio de 2018	3.2.1	1.0	Se actualizó para alinearse con PCI DSS v3.2.1. *Para conocer los cambios en PCI DSS, consulte PCI DSS - Resumen de Cambios de la Versión PCI DSS 3.2 a 3.2.1.* Se añadió el Requisito 6.2 de PCI DSS v3.2.1.
Abril de 2022	4.0		Se actualizó para alinearse con PCI DSS v4.0. Para conocer los detalles de los cambios en PCI DSS, consulte PCI DSS - Resumen de Cambios de la Versión 3.2.1 a 4.0. Se ha reordenado, retitulado y ampliado la información de la sección "Cómo Llenar el Cuestionario de Autoevaluación" (antes titulada Antes de Empezar). Alineación del contenido de las Secciones 1 y 3 del Certificado de Conformidad (AOC) con el Informe de Conformidad AOC PCI DSS v4.0. Se han añadido los requisitos de PCI DSS v4.0. Se han añadido anexos para respaldar las nuevas respuestas de los informes.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Diciembre de 2022	4.0	1	Se ha eliminado "Implementado con Remediación" como opción de informe de la tabla de Respuestas a los Requisitos, de la Parte 2g del Certificado de Cumplimiento (AOC), de la columna de Respuestas de la Sección 2 del SAQ y de la Sección 3 del AOC. También se ha eliminado el antiguo Anexo C. Se agregó "Implementado con CCW" a la Sección 3 de AOC. Se agregó la orientación para responder a los requisitos con fecha futura. Nota aclaratoria bajo los Criterios de Elegibilidad de la página iv que aborda la aplicabilidad de los Requisitos 2, 6, 8 y 11 a los comerciantes de comercios electrónicos. Notas aclaratorias que abordan la aplicabilidad a comerciantes de comercio electrónico para los Requisitos 6.4.3, 8, 11 y 11.6.1. Se agregaron aclaraciones menores y se corrigieron errores tipográficos.
Julio de 2023	4.0	2	Corregir el error tipográfico en el requisito 11.6.1 Guía para cumplimentar el SAQ: se cambió “página/formulario de pago del comerciante" por "página/formulario de pago del procesador de pagos /TPSP".
Octubre de 2024	4.0.1		Actualizado para alinearse con PCI DSS v4.0.1. Para ver los detalles de cambios en PCI ver PCI DSS –Resumen de Cambios de la Versión PCI DSS 4.0 a 4.0.1. Actualizado los Criterios de Elegibilidad del SAQ en los que el comerciante ha confirmado “que sus TPSP(s) están en conformidad con PCI DSS para los servicios utilizados por el comerciante” en lugar de que el comerciante haya revisado los AOC de los TPSP. Se agregó la Guía de Recursos ASV a la sección “Recursos Adicionales PCI SSC.” Se agregó la Guía Para Llenar el SAQ a los Requisitos 6.4.3. Se agregó el Requisito 12.3.1, ya que el cumplimiento de este requisito está especificado en el Requisito 11.6.1.
Enero de 2025	4.0.1	1	Se ha eliminado los Requisitos 6.4.3, 11.6.1 y 12.3.1 y se ha agregado un Criterio de Elegibilidad para que los comerciantes confirmen que su sitio no es susceptible a ataques de scripts que puedan afectar los sistemas de comercio electrónico del comerciante.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Contenido

Cambios en el Documento i

Llenando el Cuestionario de Autoevaluación iv

Criterios de Elegibilidad del Comerciante para el Cuestionario de Autoevaluación A iv

Definición de Datos del Titular de la Tarjeta, Datos de Tarjetahabiente y Datos de Autenticación Sensibles v

Pasos para Completar la Autoevaluación PCI DSS v

Pruebas Previstas vi

Respuestas a los Requisitos vii

Recursos Adicionales PCI SSC ix

Sección 1: Información de la Evaluación 1

Sección 2: Cuestionario de Autoevaluación A 6

Construir y Mantener una Red de Sistemas Segura 6

Requisito 2: Aplicar Configuraciones Seguras a Todos los Componentes del Sistema 6

Proteger los Datos del Titular de la Tarjeta 8

Requisito 3: Proteger los Datos del Titular de la Tarjeta Almacenados 8

Mantener un Programa de Gestión de Vulnerabilidades 11

Requisito 6: Desarrollar y Mantener Sistemas y Softwares Seguros 11

Implementar Medidas Robustas de Control de Acceso 13

Requisito 8: Identificar a los Usuarios y Autenticar el Acceso a los Componentes del Sistema 13

Requisito 9: Restringir el Acceso Físico a los Datos de Tarjetahabiente 18

Requisito 11: Poner a Prueba Regularmente la Seguridad de los Sistemas y de las Redes 20

Mantener una Política de Protección Informática 22

Requisito 12: Respaldar la Seguridad de la información con Políticas y Programas Organizacionales 22

Anexo A: Requisitos Adicionales de PCI DSS 26

Anexo A1: Requisitos Adicionales de PCI DSS para Proveedores de Servicios Multiusuario 26

Anexo A2: Requisitos Adicionales de PCI DSS Para Entidades que Utilizan SSL /Primeras Versiones de TLS para Conexiones de Terminal POS POI Presencial con Tarjetas 26

Anexo A3: Validación Suplementaria de Entidades Designadas (DESV) 26

Anexo B: Ficha de Control Compensatorio 27

Anexo C: Explicación de los Requisitos Señalados como No Aplicable 28

Anexo D: Explicación de los Requisitos Señalados como No Probado 29

Sección 3: Detalles de Validación y Certificación 30

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Llenando el Cuestionario de Autoevaluación

Criterios de Elegibilidad del Comerciante para el Cuestionario de Autoevaluación A

El Cuestionario de Autoevaluación (SAQ) sólo incluye aquellos Requisitos de PCI DSS aplicables a los comerciantes con funciones de datos del titular de la tarjeta completamente externalizadas con terceros validados y conformes con PCI DSS, en los que el comerciante sólo conserva informes o recibos en papel con datos del titular de la tarjeta.

Los comerciantes SAQ A pueden ser ya sea, comerciantes de comercio electrónico o de pedidos por correo o por teléfono (tarjeta no presente) y no almacenan, procesan ni transmiten ningún dato del titular de la tarjeta en formato electrónico en sus sistemas o locales.

Este SAQ no es aplicable a los canales de cara al público.

Este SAQ no es aplicable a los proveedores de servicios.

Los comerciantes SAQ A confirman que, para este canal de pago:

- El comerciante sólo acepta transacciones sin tarjeta (comercio electrónico o pedidos por correo o teléfono);
- Todo el procesamiento de datos del titular de la tarjeta se subcontrata íntegramente a un proveedor de servicios de terceros (TPSP)/procesador de pagos que esté en conformidad con PCI DSS;
- El comerciante no almacena, procesa o transmite electrónicamente ningún dato del titular de la tarjeta en los sistemas o instalaciones del comerciante, sino que depende enteramente de un TPSP para gestionar todas esas funciones.
- El comerciante ha confirmado que los TPSP se encuentran en conformidad con PCI DSS para los servicios utilizados por el comerciante; y
- Cualquier dato del titular de la tarjeta que el comerciante pueda conservar está impreso (por ejemplo, informes o recibos impresos), y estos documentos no se reciben electrónicamente.

Adicionalmente, para los canales de comercio electrónico:

- Todos los elementos de los formularios de las páginas de pago que se entregan al navegador del cliente se originan única y directamente en un procesador de pagos TPSP en conformidad con PCI DSS.
- El comerciante ha confirmado que su sitio no es susceptible a ataques de scripts que puedan afectar los sistemas de comercio electrónico del comerciante.

Este SAQ incluye sólo los requisitos que aplican para un tipo específico de entorno comercial, tal como se define en los criterios de elegibilidad antes mencionados. Si hay Requisitos de PCI DSS aplicables al entorno de datos de tarjetahabiente que no están cubiertos en este SAQ, esto puede ser una indicación de que este SAQ no es adecuado para el entorno del comerciante.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Nota: *Para este SAQ, los Requisitos de PCI DSS que abordan la protección de los sistemas informáticos (por ejemplo, los Requisitos 2, 6, 8 y 11) Y los requisitos que se refieren al "entorno de datos de tarjetahabiente" se aplican a los siguientes comerciantes de comercio electrónico:*

- *Aquellos que redirigen a los clientes desde su página web a un TPSP/procesador de pagos para el procesamiento de pagos, y específicamente a la página web del comerciante en el que se encuentra el mecanismo de redirección.*
- *Aquellos con página(s) web que incluya(n) una página/formulario de pago integrado de un TPSP/procesador de pago (por ejemplo, uno o más marcos en línea o iframes), y específicamente a la página web del comerciante que incluya la página/formulario de pago integrado.*

Estos requisitos PCI DSS son aplicables porque las páginas web comerciales anteriores influyen en el modo en que se transmiten los datos del titular de la tarjeta, aunque las propias páginas web no reciban los datos del titular de la tarjeta.

Los comerciantes de pedidos por correo/teléfono (MOTO) o de comercio electrónico que han externalizado completamente todas las operaciones (en las que no existe ningún mecanismo de redirección del comerciante al TPSP/procesador de pagos y ningún formulario de pago integrado de un TPSP/procesador de pagos) y, por lo tanto, no tienen ningún sistema en el ámbito de este SAQ, considerarían estos requisitos como "no aplicables". Consulte las orientaciones de las páginas siguientes para saber cómo informar de los requisitos que no son aplicables.

Definición de Datos del Titular de la Tarjeta, Datos de Tarjetahabiente y Datos de Autenticación Sensibles

Los PCI DSS está destinado a todas las entidades que almacenan, procesan o transmiten datos de tarjetahabiente (CHD) y/o datos de autenticación sensibles (SAD) o que podrían afectar la seguridad de los datos del tarjetahabiente y/o sus datos de autenticación sensibles. Los datos de tarjetahabiente y los datos de autenticación sensibles se consideran datos del titular de la tarjeta y se definen de la siguiente manera:

Datos del Titular de la Tarjeta	
Los Datos de Tarjetahabiente incluyen:	**Los Datos de Autenticación Sensibles incluyen:**
• Número de Cuenta Principal (PAN) • Nombre del Tarjetahabiente • Fecha de Expiración • Código de Servicio	• Datos de pista completos (datos de banda magnética o equivalentes en un chip) • Código de Verificación de la Tarjeta • PINs / Bloques de PIN

Refiérase a la Sección 2 PCI DSS, *Información de Aplicabilidad PCI DSS,* para más detalles.

Pasos para Completar la Autoevaluación PCI DSS

1. Confirme mediante revisión de los criterios de elegibilidad en este SAQ y en el documento *Instrucciones y Lineamientos del Cuestionario de Autoevaluación* en el sitio web de PCI SSC, que se trata del SAQ correcto para el entorno del comerciante.
2. Confirme que el entorno del comerciante está correctamente enfocado.
3. Evalúe el entorno para comprobar la conformidad con los requisitos PCI DSS.
4. Llene todas las secciones de este documento:

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

- Sección 1: Información de la Evaluación (partes 1 y 2 de la Declaración de Conformidad (AOC): Información de Contacto y Resumen Ejecutivo).
- Sección 2: Cuestionario de Auto-evaluación A.
- Sección 3: Detalles de Validación y Certificación (Partes 3 & 4 de la AOC - Validación PCI DSS y Plan de Acción para Requisitos de No-Conformidad (si aplica la Parte 4)).

5. Presente el SAQ y el AOC, junto con cualquier otra documentación solicitada -tal como los informes ASV escaneados - a la organización solicitante (aquellas organizaciones que gestionan los programas de conformidad, tal como las marcas de pago y los adquirentes).

Pruebas Previstas

Las instrucciones que aparecen en la columna "Pruebas Previstas" se basan en los procedimientos de prueba PCI DSS y brindan una descripción de alto nivel de los tipos de actividades de prueba que se esperan que un comerciante desarrolle para verificar que se ha cumplido con un requisito.

La intención de cada método de prueba se describe como sigue:

- Evalúe: El comerciante evalúa críticamente las evidencias de datos. Algunos ejemplos comunes incluyen documentos (electrónicos o físicos), capturas de pantalla, archivos de configuración, registros de auditoría y archivos de datos.
- Observe: El comerciante observa una acción o percibe algo en el entorno. Algunos ejemplos de sujetos de observación incluyen el desempeño del personal en una tarea o un proceso, los componentes del sistema que realizan una función o responden a una entrada, las condiciones del entorno y los controles físicos.
- Entreviste: El comerciante conversa con el personal de manera individual. Los objetivos de la entrevista pueden incluir la confirmación de si se realiza una actividad, las descripciones de cómo se realiza una actividad y si el personal tiene conocimientos o comprensión particulares.

Los métodos de prueba tienen por objeto permitir al comerciante demostrar cómo ha cumplido un requisito. Los elementos específicos que deben evaluarse u observarse y el personal que será entrevistado deben ser apropiados tanto para el requisito que se está evaluando como para la implementación particular de la entidad.

Los detalles completos de los procedimientos de prueba para cada requisito pueden encontrarse en PCI DSS.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Respuestas a los Requisitos

Para cada elemento del requisito hay una opción de respuestas para indicar la situación del comerciante con respecto a ese requisito. ***Sólo se debe seleccionarse una respuesta por cada elemento del requisito.***

En la tabla siguiente se describe el significado de cada respuesta y cuándo se debe utilizar cada una de ellas:

Respuesta	Cuándo utilizar esta respuesta:
Implementado	Se han realizado las pruebas previstas y se ha cumplido con todos los elementos del requisito según lo establecido.
Implementado con CCW (Hoja de Control Compensatorio)	Se han realizado las pruebas previstas y el requisito se ha cumplido con la ayuda de un control compensatorio. Todas las respuestas en esta columna requieren que se llene la Hoja de Control Compensatorio (CCW) que aparece en el Anexo B de este SAQ. En los Anexos B y C PCI DSS se proporciona información sobre el uso de controles compensatorios y orientación sobre cómo llenar la hoja de trabajo.
No Aplicable	El requisito no aplica para el entorno de la comerciante. (Refiérase a la " Orientación sobre los Requisitos No Aplicables" que aparece a continuación). Todas las respuestas en esta columna requieren una explicación de respaldo en el Anexo C de este SAQ.
No Probado	*La respuesta no es aplicable y no se incluye como opción para este SAQ.* *Este SAQ fue creado para un tipo específico de entorno basado en la forma en que el comerciante almacena, procesa y/o transmite los datos del titular de la tarjeta y define los requisitos específicos PCI DSS que aplican para este entorno. Por lo tanto, todos los requisitos de este SAQ deben ser probados.*
No Implementado	Algunos o todos los elementos del requisito no se han cumplido, o están en proceso de implementación, o requieren más pruebas antes de que el comerciante pueda confirmar que han sido implementados. Las respuestas de esta columna pueden requerir la ejecución de la Parte 4 si así lo solicita la entidad a la que se presentará este SAQ. Esta respuesta también se utiliza si un requisito no puede cumplirse debido a una restricción legal. (Para más orientación refiérase a "Excepción legal" más adelante).

Orientación sobre los Requisitos No Aplicables

Si algún requisito no aplica para el entorno del comerciante, seleccione la opción No Aplicable para ese requisito específico. Por ejemplo, en este SAQ, los requisitos para asegurar todos los medios con los datos de tarjetahabiente (Requisitos 9.4.1 - 9.4.6) sólo se aplican si el comerciante almacena medios en papel con datos de tarjetahabiente; si no se almacenan medios en papel, el comerciante puede seleccionar No Aplicable para esos requisitos.

Para cada respuesta en la que se seleccione No Aplicable en este SAQ, llene el *Anexo C*: *Explicación de los Requisitos Señalados como No Aplicable*

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Orientación para Responder a Requisitos con Fecha Futura

En la Sección 2 a continuación, cada requisito o punto PCI DSS con un período de implementación extendido incluye la siguiente nota: *"Este requisito [o punto] es una práctica recomendada hasta el 31 de marzo de 2025, fecha a partir de la cual será obligatorio y deberá tenerse en cuenta en su totalidad durante una evaluación PCI DSS.*

No se requiere que estos nuevos requisitos se incluyan en una evaluación PCI DSS hasta que haya pasado la fecha futura. Antes de esa fecha futura, cualquier requisito con una fecha de implementación extendida que no haya sido implementado por el comerciante puede marcarse como No aplicable y documentarse en el *Anexo C: Explicación de los Requisitos Señalados como No Aplicable***.**

Excepción Legal

Si su organización está sujeta a una restricción legal que le impide cumplir con un Requisito de PCI DSS, seleccione No Implementado para ese requisito y llene la declaración correspondiente en la Sección 3, Parte 3 de este SAQ.

Nota: *Una excepción legal es una restricción legal debido a una ley, regulación o requisito regulatorio local o regional, donde cumplir con un requisito del PCI DSS violaría esa ley, regulación o requisito regulatorio. Las obligaciones contractuales o el asesoramiento legal no son restricciones legales.*

Las obligaciones contractuales o el asesoramiento legal no son restricciones legales.

Uso del Enfoque Personalizado

Los SAQs no pueden utilizarse para documentar el uso del Enfoque Personalizado para cumplir con los requisitos PCI DSS. Por esta razón, los Objetivos del Enfoque Personalizado no se incluyen en los SAQ. Las entidades que deseen validar el uso del Enfoque Personalizado pueden utilizar la Plantilla de Informe de Conformidad (ROC) PCI DSS para documentar los resultados de su evaluación.

El Uso del Enfoque Personalizado no está contemplado en los SAQs.

El uso del enfoque personalizado puede ser regulado por las organizaciones que administran los programas de conformidad, como las marcas de pago y los adquirentes. Las preguntas sobre el uso de un enfoque personalizado deben remitirse siempre a esas organizaciones. Esto incluye si una entidad que es elegible para un SAQ puede, en cambio, completar un ROC para usar un enfoque personalizado, y si se requiere que una entidad utilice QSA, o puede usar un ISA, para completar una evaluación utilizando el enfoque personalizado. La información acerca del uso del Enfoque Personalizado puede encontrarse en los Anexos D y E de PCI DSS.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Recursos Adicionales PCI SSC

A continuación, se ofrecen recursos adicionales que proporcionan orientación sobre los Requisitos de PCI DSS y sobre cómo llenar el cuestionario de autoevaluación para ayudarle en el proceso de evaluación.

Recurso	Incluye:
Requisitos y Procedimientos de Prueba del Estándar de Seguridad de Datos PCI (PCI DSS)	▪ Orientación sobre el Alcance ▪ Orientación sobre el objetivo de todos los Requisitos de PCI DSS ▪ Detalles de los Procedimientos de Prueba ▪ Guía de los Controles Compensatorios ▪ Anexo G: Glosario de Términos, Abreviaturas y Acrónimos
Instrucciones y Directrices SAQ	▪ Información sobre todos los SAQ y sus Criterios de Elegibilidad ▪ Cómo determinar qué SAQ es el adecuado para su organización
Preguntas frecuentes (FAQ)	▪ Orientación e Información acerca de los SAQ.
Glosario PCI DSS en línea	▪ Términos, Abreviaturas y Acrónimos PCI DSS
Información Complementaria y Directrices	▪ Directrices en varios temas PCI DSS incluyendo: – *Comprendiendo el Alcance PCI DSS y la Segmentación de la Red* – *Garantía de Seguridad de Terceros* – *Orientación sobre la Autenticación Multifactorial* – *Mejores Prácticas para Mantener la Conformidad con PCI DSS*
Introducción a PCI	▪ Recursos para pequeños comerciantes, incluyendo: – *Guía de Pagos Seguros* – *Sistemas de Pago Comunes* – *Preguntas que hacer a sus Proveedores* – *Glosario de Términos de Seguridad de Pagos e Información* – *Conceptos Básicos PCI Firewall* – *Guía de Recursos ASV*

Estos y otros recursos pueden encontrarse en el sitio web del PCI SSC *(www.pcisecuritystandards.org)*.

Se recomienda a las organizaciones que revisen los documentos PCI DSS y otros documentos de respaldo antes de comenzar una evaluación.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Sección 1: Información de la Evaluación

Instrucciones para la Presentación

Este documento debe ser completado como una declaración de los resultados de la autoevaluación del comerciante con respecto a los *Requisitos y Procedimientos de Prueba del Estándar de Seguridad de Datos de Payment Card Industry (PCI DSS)* Complete todas las secciones. El comerciante es responsable de garantizar que cada sección sea completada por las partes pertinentes, según corresponda. Póngase en contacto con la(s) entidad(es) que recibirán el AOC para los procedimientos de elaboración de informe y presentación.

Parte 1. Información de Contacto	
Parte 1a. Comerciante Evaluado	
Nombre de la compañía:	
DBA (actuando comercialmente como):	
Dirección postal de la compañía:	
Sitio web principal de la compañía:	
Nombre del contacto de la compañía:	
Título del contacto de la compañía:	
Número de teléfono de contacto:	
Dirección de correo electrónico de contacto:	
Parte 1b. Asesor	
Provea la siguiente información sobre todos los asesores que participaron en la evaluación. Si no hubo asesor para un tipo de asesor determinado, introduzca "No aplicable".	
Asesores de Seguridad Interna del PCI SSC	
Nombre del ISA:	
Asesor de Seguridad Calificado	
Nombre de la compañía:	
Dirección postal de la compañía:	
Página web de la compañía:	
Nombre del Asesor principal:	
Número de teléfono del asesor:	
Dirección de correo electrónico del asesor:	
Número de certificado del asesor:	

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 2. Resumen Ejecutivo

Parte 2a. Canales de Pago del Comerciante (seleccione todos los que apliquen):

Indique todos los canales de pago utilizados por la empresa que se incluyen en esta Evaluación.

☐ Pedido por correo / por teléfono (MOTO)

☐ Comercio electrónico

☐ Presencial

¿Hay algún canal de pago que no esté incluido en esta evaluación? En caso afirmativo, indique qué canal(les) no están incluidos en la evaluación y explique brevemente por qué se han excluido.	☐ Sí ☐ No

Nota: Si el comerciante tiene un canal de pago no cubierto por esta SAQ, consulte con la(s) entidad(es) a la(s) que se presentará esta *AOC* acerca de la validación para los otros canales.

Parte 2b. Descripción de la Función con Tarjetas de Pago

Para cada canal de pago incluido en esta Evaluación seleccionado en la Parte 2a previa, describa cómo el comerciante almacena, procesa y/o transmite los datos del titular de la tarjeta.

Canal	**Cómo la Empresa Almacena, Procesa y/o Transmite los Datos del Titular de la Tarjeta**

Parte 2c. Descripción del Entorno de las Tarjetas de Pago

Proporcione una descripción de ***alto- nivel*** del entorno cubierto por esta evaluación. *Por ejemplo:* • *Conexiones desde y hacia el entorno de datos de tarjetahabiente (CDE).* • *Componentes críticos del sistema dentro del CDE, tales como dispositivos POI, bases de datos, servidores web, etc., y cualquier otro componente de pago necesario, según corresponda.* • *Componentes del sistema que podrían afectar la seguridad de los datos del titular de la tarjeta.*	
Indique si el entorno incluye la segmentación para reducir el alcance de la evaluación. *(Consulte la sección "Segmentación" de PCI DSS para obtener orientación sobre la segmentación).*	☐ Sí ☐ No

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 2. Resumen Ejecutivo *(continuación)*

Parte 2d. Localidades e Instalaciones en el Ámbito de Aplicación

Enumere todos los tipos de locaciones/instalaciones (por ejemplo, establecimientos minoristas, oficinas corporativas, centros de datos, centros de llamadas y salas de correo) en el ámbito de la evaluación PCI DSS.

Tipo de Instalación	**Número total de Instalaciones** (Cuántas instalaciones de este tipo se encuentran dentro del ámbito)	**Ubicación(ones) de las Instalaciones (ciudad, país)**
Ejemplo: Centros de Datos	*3*	*Boston, MA, USA*

Parte 2e. Productos y Soluciones Validados por PCI SSC

¿Utiliza el comerciante algún elemento identificado en alguna de las Listas de Productos y Soluciones Validados por PCI SSC♦?

☐ Sí ☐ No

Provea la siguiente información sobre cada elemento que el comerciante utilice de las Listas de Productos y Soluciones Validados por PCI SSC:

Nombre del Producto o Solución Validado por PCI SSC	**Versión del Producto o Solución**	**Estándar PCI SSC según el cual se validó el producto o solución**	**Número de Referencia de la Lista PCI SSC**	**Fecha de Expiración de la Lista** (DD-MM-AAAA)
				DD-MM-AAAA
				DD-MM-AAAA
				DD-MM-AAAA
				DD-MM-AAAA
				DD-MM-AAAA
				DD-MM-AAAA
				DD-MM-AAAA
				DD-MM-AAAA
				DD-MM-AAAA
				DD-MM-AAAA

♦ Para los fines de este documento, se entenderá por "Listas de Productos y Soluciones Validados" las listas de productos, soluciones y/o componentes validados que aparecen en el sitio web de PCI SSC (www.pcisecuritystandards.org) por ejemplo, los Kits de Desarrollo de Software 3DS, los Dispositivos PTS Aprobados, el Software de Pago Validado, las Soluciones Cifradas de Punto a Punto (P2PE), las Soluciones de Introducción de PIN basadas en software en COTS (SPoC), las Soluciones de Pago sin contacto en COTS (CPoC) y los Productos de Métodos de Pagos Móviles en COTS (MPoC).

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 2. Resumen Ejecutivo *(continuación)*

Parte 2f. Proveedores de Servicios Externos

Tiene el comerciante relaciones con uno o más proveedores de servicios externos que:

• Almacenan, procesan o transmiten datos del titular de la tarjeta en nombre del comerciante (por ejemplo, pasarelas de pago, procesadores de pago, proveedores de servicios de pago (PSP) y almacenamiento externo)	☐ Sí ☐ No
• Gestionan los componentes del sistema incluidos en el ámbito de la evaluación PCI DSS del comerciante, por ejemplo, a través de servicios de control de seguridad de la red, servicios *antimalware*, gestión de eventos e incidentes de seguridad (SIEM), centros de contacto y de llamadas, servicios de alojamiento web y proveedores de IaaS, PaaS, SaaS y FaaS en la nube.	☐ Sí ☐ No
• Podrían afectar la seguridad del CDE del comerciante (por ejemplo, proveedores que prestan asistencia a través de acceso remoto, y/o desarrolladores de software a la medida).	☐ Sí ☐ No

En caso afirmativo:

Nombre del proveedor de servicio:	**Descripción del servicio(s) prestado(s):**

Nota: *El requisito 12.8 aplica a todas las entidades que aparecen en la lista.*

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 2. Resumen Ejecutivo *(continuación)*

Parte 2g. Resumen de la Evaluación
(Sección 2 del SAQ y anexos relacionados)

Indique a continuación todas las respuestas seleccionadas para cada requisito de PCI DSS.

Requisito de PCI DSS*	Respuestas a los Requisitos *Se puede seleccionar más de una respuesta para un requisito determinado. Indique todas las respuestas que correspondan.*			
	Implementado	Implementado con CCW	No Aplicable	No Implementado
Requisito 2:	☐	☐	☐	☐
Requisito 3:	☐	☐	☐	☐
Requisito 6:	☐	☐	☐	☐
Requisito 8:	☐	☐	☐	☐
Requisito 9:	☐	☐	☐	☐
Requisito 11:	☐	☐	☐	☐
Requisito 12:	☐	☐	☐	☐

** Los Requisitos de PCI DSS indicados anteriormente se refieren a los requisitos de la Sección 2 de este SAQ.*

Parte 2h. Elegibilidad para llenar el SAQ A

El comerciante certifica la elegibilidad para llenar este Cuestionario de Autoevaluación para este canal de pago porque:

☐	El comerciante sólo acepta transacciones sin tarjeta (comercio electrónico o pedidos por correo o teléfono).
☐	Todo el procesamiento de datos del titular de la tarjeta se subcontrata por completo a un proveedor de servicios externos (TPSP)/procesador de pagos que se encuentre en conformidad con PCI DSS.
☐	El comerciante no almacena, procesa o transmite electrónicamente ningún datos del titular de la tarjeta en los sistemas o instalaciones del comerciante, sino que depende enteramente de un TPSP para gestionar todas esas funciones.
☐	El comerciante ha confirmado que los TPSP se encuentran en conformidad con PCI DSS para los servicios utilizados por el comerciante.
☐	Cualquier datos del titular de la tarjeta que el comerciante pueda conservar está impreso (por ejemplo, informes o recibos impresos), y estos documentos no se reciben electrónicamente.

Adicionalmente, para los canales de comercio electrónico, el comerciante certifica:

☐	Todos los elementos de los formularios de las páginas de pago que se entregan al navegador del cliente se originan única y directamente en un procesador de pagos TPSP en conformidad con PCI DSS.
☐	El comerciante ha confirmado que su sitio no es susceptible a ataques de scripts que puedan afectar los sistemas de comercio electrónico del comerciante.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Sección 2: Cuestionario de Autoevaluación A

Nota: *Los siguientes requisitos son un reflejo de los requisitos del documento* de Requisitos y Procedimientos de Prueba PCI DSS.

Fecha de finalización de la autoevaluación: DD-MM-AAAA

Construir y Mantener una Red de Sistemas Segura

Requisito 2: Aplicar Configuraciones Seguras a Todos los Componentes del Sistema

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ *(Marque una respuesta para cada requisito)*			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
2.2 Los componentes del sistema se configuran y gestionan de forma segura.						
Nota: *Para SAQ A, el Requisito 2.2.2 se aplica a las cuentas predeterminadas de los comerciantes de comercio electrónico en los servidores web.*						
2.2.2	Las cuentas predeterminadas del proveedor se gestionan de la siguiente manera: • Si se utilizan las cuentas predeterminadas del proveedor, la contraseña predeterminada se cambia según el requisito 8.3.6. • Si no se van a utilizar las cuentas predeterminadas del proveedor, la cuenta se elimina o se desactiva. *(continuación)*	• Evalúe los estándares de configuración del sistema. • Evalúe la documentación del proveedor. • Observe a un administrador del sistema iniciando sesión con las cuentas predeterminadas del proveedor. • Evalúe los archivos de configuración. • Entreviste al personal.	☐	☐	☐	☐

♦ *Consulte la sección "Respuestas a los Requisitos" (página vii) para obtener información sobre estas opciones de respuesta.*

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS	Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
		Implementado	Implementado con CCW	No Aplicable	No Implementado
	Notas de Aplicabilidad				
	Esto se aplica a TODAS las cuentas y contraseñas predeterminadas del proveedor, incluidas, entre otras, las utilizadas por los sistemas operativos, el software que proporciona servicios de seguridad, las cuentas de aplicaciones y sistemas, los terminales de punto de venta (POS), las aplicaciones de pago y los valores predeterminados del Protocolo Simple de Administración de Red (SNMP). Este requisito también se aplica cuando un componente del sistema no está instalado en el entorno de una entidad, por ejemplo, el software y las aplicaciones que forman parte del CDE y a las que se ingresa a través de un servicio de suscripción en la nube.				

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Proteger los Datos del Titular de la Tarjeta

Requisito 3: Proteger los Datos del Titular de la Tarjeta Almacenados

***Nota**: En el caso de SAQ A, el Requisito 3 sólo se aplica a los comerciantes con registros en papel que incluyan datos del titular de la tarjeta (por ejemplo, recibos o informes impresos).*

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
3.1 Se definen y comprenden los procesos y mecanismos para proteger los datos del titular de la tarjeta almacenados.						
3.1.1	Todas las políticas de seguridad y procedimientos operacionales que se identifican en el Requisito 3 son: • Documentados. • Actualizados. • En uso. • Conocidos por todas las partes involucradas.	• Evalúe la documentación. • Entreviste al personal.	☐	☐	☐	☐

Guía para llenar el SAQ:

La selección de cualquiera de las respuestas Implementado para el Requisito 3.1.1 significa que, si el comerciante almacena los datos del titular de la tarjeta en papel, el comerciante dispone de políticas y procedimientos que rigen sus las actividades con respecto al Requisito 3. Esto ayuda a garantizar que el personal conoce y sigue las políticas de seguridad y los procedimientos operativos documentados para gestionar el almacenamiento seguro de cualquier registro en papel con datos del titular de la tarjeta.

Si el comerciante no almacena registros en papel con datos del titular de la tarjeta, marque este requisito como No aplicable y llene el Anexo C: Explicación de los Requisitos Señalados como No Aplicable.

♦ *Consulte la sección "Respuestas a los Requisitos" (página vii) para obtener información sobre estas opciones de respuesta.*

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
3.2 El almacenamiento de los datos del titular de la tarjeta se mantiene al mínimo.						
3.2.1	El almacenamiento de datos del titular de la tarjeta se mantiene al mínimo mediante la implementación de políticas y procedimientos de retención y eliminación de datos que incluyan al menos lo siguiente: • Cobertura de todas las ubicaciones de los datos del titular de la tarjeta almacenados. • Cobertura de cualquier dato de autenticación sensible (SAD) almacenado antes de completar la autorización. *Este punto es una de las mejores prácticas hasta su fecha de vigencia; refiérase a las Notas de Aplicabilidad que aparecen a continuación para obtener más detalles.* • Limitar la cantidad de datos almacenados y el tiempo de retención que se requiere establecidos por los requisitos legales o reglamentarios y/o comerciales. • Requisitos de retención específicos para los datos del titular de la tarjeta almacenados que definen la duración del período de retención e incluyen una justificación comercial documentada. • Procesos para la eliminación segura o para hacer que los datos del titular de la tarjeta que sean irrecuperables cuando ya no se necesitan según la política de retención. Un proceso para verificar, al menos una vez cada tres meses, que los datos del titular de la tarjeta almacenados que excedan el período de retención definido se han eliminado de forma segura o se han vuelto irrecuperables. *(continuación)*	• Evalúe las políticas, procedimientos y procesos de conservación y eliminación de datos. • Entreviste al personal • Evalúe los archivos y registros del sistema en los componentes del sistema en los que se almacenan los datos del titular de la tarjeta. • Observe los mecanismos utilizados para hacer que los datos del titular de la tarjeta sean irrecuperables.	☐	☐	☐	☐

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS	Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
		Implementado	Implementado con CCW	No Aplicable	No Implementado
Notas de Aplicabilidad *Parte de esta Nota de Aplicabilidad se eliminó intencionadamente, ya que no se aplica a las evaluaciones de SAQ A.* *El punto anterior (sobre datos SAD almacenados antes de completar la autorización) es una mejor práctica hasta el 31 de marzo de 2025, después de lo cual se requerirá como parte del Requisito 3.2.1 y se debe considerar en su totalidad durante una evaluación PCI DSS.*					

Guía para llenar el SAQ:

La selección de cualquiera de las respuestas Implementado para el requisito 3.2.1 significa que si una empresa almacena cualquier papel (por ejemplo, recibos o informes en papel) que contenga datos del titular de la tarjeta, el comerciante sólo almacena el papel mientras sea necesario por motivos comerciales, legales y/o normativos y destruye el papel cuando ya no se necesite.

Si el comerciante no imprime ni almacena nunca ningún papel que contenga datos del titular de la tarjeta, marque este requisito como No aplicable y llene el Anexo C: Explicación de los Requisitos Señalados como No Aplicable.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Mantener un Programa de Gestión de Vulnerabilidades

Requisito 6: Desarrollar y Mantener Sistemas y Softwares Seguros

***Nota**: Para el SAQ A, el Requisito 6 se aplica a los servidores de comerciante con una página web que 1) redirigen a los clientes de la página web comercial a un TPSP/procesador de pagos para el procesamiento de pagos (por ejemplo, con una redirección de URL) o 2) incluyen una Página/formulario de pago integrado del TPSP/procesador de pago (por ejemplo, uno o más marcos en línea o iframes).*

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
6.3 Las vulnerabilidades de seguridad se identifican y son abordadas.						
6.3.1	Las vulnerabilidades de seguridad se identifican y gestionan de la siguiente manera: • Las nuevas vulnerabilidades de seguridad se identifican utilizando fuentes reconocidas por la industria de información de vulnerabilidades de seguridad, incluyendo alertas de equipos internacionales y nacionales de respuesta a emergencias informáticas (CERTs). • A las vulnerabilidades se les asigna una clasificación de riesgo basada en las mejores prácticas de la industria y considerando su impacto potencial. • Las clasificaciones de riesgo identifican, como mínimo, todas las vulnerabilidades consideradas de alto riesgo o críticas para el entorno. • *Punto dejado en blanco intencionadamente para este SAQ.* *(continuación)*	• Evalúe las políticas y procedimientos. • Entreviste al personal responsable. • Evalúe la documentación • Observe los procesos.	☐	☐	☐	☐

♦ *Consulte la sección "Respuestas a los Requisitos" (página vii) para obtener información sobre estas opciones de respuesta.*

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
	Notas de Aplicabilidad Este requisito no se consigue con los escaneos, y es adicional a la realización de los escaneos de vulnerabilidades realizados para los Requisitos 11.3.1 y 11.3.2. Este requisito se refiere a un proceso para monitorizar activamente las fuentes de la industria en materia de información de vulnerabilidades y para que la entidad determine la clasificación de riesgo que se asociará con cada vulnerabilidad.					
6.3.3	• Todos los componentes del sistema están protegidos contra vulnerabilidades conocidas mediante la instalación de parches/actualizaciones de seguridad aplicables de la siguiente manera: • Los parches/actualizaciones para vulnerabilidades críticas (identificados de acuerdo con el proceso de clasificación de riesgos del Requisito 6.3.1) se instalan dentro del período de un mes de su emisión. • *Punto dejado en blanco intencionadamente para este SAQ.*	• Evalúe las políticas y procedimientos. • Evalúe los componentes del sistema y software relacionado. • Compare la lista de parches de seguridad instalados con las listas de parches del proveedor recientes.	☐	☐	☐	☐

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Implementar Medidas Robustas de Control de Acceso

Requisito 8: Identificar a los Usuarios y Autenticar el Acceso a los Componentes del Sistema

***Nota**: Para el SAQ A, el Requisito 8 se aplica a los servidores de comerciante con una página web que 1) redirigen a los clientes del sitio web comercial a un TPSP/procesador de pagos para el procesamiento de pagos (por ejemplo, con una redirección de URL) o 2) incluyen una Página/formulario de pago integrado del TPSP/procesador de pago (por ejemplo, uno o más marcos en línea o iframes).*

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ *(Marque una respuesta para cada requisito)*			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
8.2 La identificación de usuarios y las cuentas relacionadas para usuarios y administradores se gestionan estrictamente durante el ciclo de vida de una cuenta.						
8.2.1	A todos los usuarios se les asigna una identificación única antes de permitirles el acceso a los componentes del sistema o a los datos de tarjetahabiente.	• Entreviste al personal responsable. • Evalúe los registros de auditoría y otras evidencias.	☐	☐	☐	☐
	Notas de Aplicabilidad Este requisito no está destinado a aplicarse a las cuentas de usuario de los terminales de punto de venta que sólo tienen acceso a un número de tarjeta simultáneamente para procesar una única transacción.					

♦ *Consulte la sección "Respuestas a los Requisitos" (página vii) para obtener información sobre estas opciones de respuesta.*

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
8.2.2	Las identificaciones IDs de grupos, compartidas o genéricas, u otras credenciales de autenticación compartidas sólo se usan cuando es necesario, de manera excepcional, y se administran de la siguiente manera: • Se impide el uso de la ID a menos que se requiera por una circunstancia excepcional. • El uso está limitado al tiempo necesario para la circunstancia excepcional. • La justificación comercial para su uso está documentada. • El uso está explícitamente aprobado por la dirección • La identidad del usuario individual se confirma antes de que se conceda el acceso a una cuenta. • Cada acción realizada es atribuible a un usuario individual	• Evalúe las listas de cuentas de usuario en los componentes del sistema y la documentación aplicable. • Evalúe las políticas y procedimientos de autenticación. • Entreviste a los administradores del sistema.	☐	☐	☐	☐
	Notas de Aplicabilidad Este requisito no está destinado a aplicarse a las cuentas de usuario de los terminales de punto de venta que sólo tienen acceso a un número de tarjeta simultáneamente para procesar una única transacción.					
8.2.5	El acceso para los usuarios rescindidos se revoca inmediatamente.	• Evalúe las fuentes de información para los usuarios que han sido dados de baja. • Revise las listas de acceso de los usuarios actuales. • Entreviste al personal responsable.	☐	☐	☐	☐

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
8.3 Se establece y gestiona una autenticación robusta para usuarios y administradores.						
8.3.1	Todo el acceso de los usuarios y administradores a los componentes del sistema se autentifica utilizando al menos uno de los siguientes factores de autenticación: • Algo que uno sabe, como una contraseña o frase de paso. • Algo que uno tiene, como un dispositivo token o una tarjeta inteligente. • Algo que se es, como un elemento biométrico.	• Evalúe la documentación que describe el factor o factores de autenticación utilizados. • Para cada tipo de factor de autenticación utilizado con cada tipo de componente del sistema, observe el proceso de autenticación.	☐	☐	☐	☐
	Notas de Aplicabilidad Este requisito no está destinado a aplicarse a las cuentas de usuario de los terminales de punto de venta que sólo tienen acceso a un número de tarjeta simultáneamente para procesar una única transacción. Este requisito no sustituye a los requisitos de autenticación de múltiples factores (MFA), sino que se aplica a los sistemas incluidos en el ámbito de aplicación que no están sujetos a los requisitos de los MFA. El certificado digital es una opción válida para "algo que se tiene" si es único para un usuario concreto.					
8.3.5	Si las contraseñas/frases de paso se utilizan como factores de autenticación para cumplir con el requisito 8.3.1, estas se establecen y restablecen para cada usuario tal y como sigue: • Se establece un valor único para la primera vez que se utilizan y al restablecerse. • Existe la obligatoriedad de cambiarlos inmediatamente después del primer uso.	• Evalúe los procedimientos para establecer y restablecer las contraseñas/frases de paso. • Observe al personal de seguridad.	☐	☐	☐	☐

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
8.3.6	Si las contraseñas/frases de paso se utilizan como factores de autenticación para cumplir el requisito 8.3.1, estas deberán cumplir el siguiente nivel mínimo de complejidad: • Una longitud mínima de 12 caracteres (o SI el sistema no admite 12 caracteres, una longitud mínima de ocho caracteres). • Contener tanto caracteres numéricos como alfabéticos.	• Evalúe los ajustes de configuración del sistema.	☐	☐	☐	☐
	Notas de Aplicabilidad Este requisito no se aplica a: • Cuentas de usuario de los terminales de punto de venta que sólo tienen acceso a un número de tarjeta simultáneamente para procesar una única transacción. • Cuentas de aplicaciones o sistemas, que se rigen por los requisitos de la sección 8.6. *Este requisito es una práctica recomendada hasta el 31 de marzo de 2025, después de lo cual será obligatorio y debe tenerse en cuenta en su totalidad durante una evaluación PCI DSS.* Hasta el 31 de marzo de 2025, las contraseñas deben tener una longitud mínima de siete caracteres, de acuerdo con el requisito 8.2.3 PCI DSS v3.2.1.					
8.3.7	Las personas no pueden enviar una nueva contraseña / frase de paso que sea igual a cualquiera de las últimas cuatro contraseñas / frases de paso utilizadas.	• Evalúe los ajustes de configuración del sistema.	☐	☐	☐	☐
	Notas de Aplicabilidad Este requisito no está destinado a aplicarse a las cuentas de usuario de los terminales de punto de venta que sólo tienen acceso a un número de tarjeta simultáneamente para procesar una única transacción.					

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
8.3.9	Si las contraseñas/frases de paso se utilizan como el único factor de autenticación para el acceso del usuario (es decir, en cualquier implementación de autenticación de factor único), entonces: • Las contraseñas/frases de paso se cambian al menos una vez cada 90 días, **O** • La postura de seguridad de las cuentas se analiza dinámicamente y el acceso a los recursos en tiempo real se determina automáticamente de acuerdo a dicha postura de seguridad.	• Inspeccione los ajustes de configuración del sistema.	☐	☐	☐	☐
	Notas de Aplicabilidad Este requisito no se aplica a los componentes del sistema incluidos en el ámbito de aplicación en los que se utilice MFA. Este requisito no se aplica a las cuentas de usuarios de terminales de puntos de venta que sólo tienen acceso a un número de tarjeta a la vez para facilitar una única transacción. Este requisito no se aplica a las cuentas de clientes de proveedores de servicios, pero se aplica a las cuentas del personal del proveedor de servicios.					

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito 9: Restringir el Acceso Físico a los Datos de Tarjetahabiente

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
9.4 Los medios con datos de tarjetahabiente se almacenan, acceden, distribuyen y destruyen de forma segura.						
Nota: *Para el SAQ A, los Requisitos del punto 9.4 sólo se aplican a los comerciantes con registros en papel (por ejemplo, recibos o informes impresos) con datos del titular de la tarjeta, incluidos los números de cuenta principales (PAN).*						
9.4.1	Todos los soportes con datos de tarjetahabiente están protegidos físicamente.	• Evalúe la documentación.	☐	☐	☐	☐
9.4.1.1	Las copias de seguridad sin conexión con los datos de tarjetahabiente se almacenan en una ubicación segura.	• Evalúe los procedimientos documentados. • Evalúe los registros u otra documentación. • Entreviste al personal responsable de en el sitio de almacenamiento.	☐	☐	☐	☐
9.4.2	Todos los datos de tarjetahabiente se clasifican de acuerdo con la confidencialidad de esos datos.	• Evalúe los procedimientos documentados. • Evalúe los registros en medios u otra documentación.	☐	☐	☐	☐
9.4.3	Los respaldos con datos de tarjetahabiente enviados fuera de las instalaciones se protegen de la siguiente manera: • *Punto dejado en blanco intencionadamente para este SAQ.* • Los datos se envían por mensajería segura u otro método de entrega que pueda ser rastreado con precisión. • *Punto dejado en blanco intencionadamente para este SAQ.*	• Evalúe los procedimientos documentados. • Entreviste al personal. • Evalúe los registros. • Evalúe los registros de seguimiento externo de todos los medios.	☐	☐	☐	☐

♦ *Consulte la sección "Respuestas a los Requisitos" (página vii) para obtener información sobre estas opciones de respuesta.*

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
9.4.4	La gerencia aprueba todos los movimientos de apoyos con datos de tarjetahabiente que se trasladan fuera de las instalaciones (incluso cuando son distribuidos a particulares).	• Evalúe los procedimientos documentados. • Evalúe los registros de seguimiento externo • Entreviste al personal responsable.	☐	☐	☐	☐
	Notas de Aplicabilidad Las personas que aprueban los movimientos de los apoyos deben tener el nivel adecuado de autoridad de gestión para conceder esta aprobación. Sin embargo, no se requiere específicamente que dichas personas tengan el título de "gerente".					
9.4.6	Los materiales impresos con datos de tarjetahabiente se destruyen cuando ya no se necesitan por razones de negocios o legales, de la siguiente manera: • Los materiales se trituran transversalmente, se incineran o se pulverizan de forma que los datos de tarjetahabiente no puedan reconstruirse. • Los materiales se guardan en contenedores de almacenamiento seguro antes de su destrucción.	• Evalúe la política de destrucción periódica de medios. • Observe los procesos. • Entreviste al personal. • Observe los contenedores de almacenamiento.	☐	☐	☐	☐
	Notas de Aplicabilidad Estos requisitos relativos a la destrucción de materiales impresos cuando éstos ya no son necesarios por motivos de negocio o legales son independientes y distintos del requisito 3.2.1 PCI DSS, que se refiere a la eliminación segura de los datos de los titulares de tarjetas cuando ya no son necesarios de acuerdo con las políticas de retención de datos de los titulares de tarjetas de la entidad.					

Guía para llenar el SAQ:

La selección de cualquiera de las respuestas Implementado para los Requisitos de la sección 9.4 significa que el comerciante almacena de forma segura cualquier soporte de papel con datos del titular de la tarjeta, por ejemplo, guardando el papel en un cajón, armario o caja fuerte cerrados con llave, y que el comerciante destruye dicho papel cuando ya no lo necesita para fines de negocios. Esto incluye un documento escrito o una política para los empleados, de manera que ellos sepan cómo proteger el papel con los datos del titular de la tarjeta y cómo destruir el papel cuando ya no lo necesiten.

Si el comerciante nunca imprime ni almacena ningún papel que contenga datos del titular de la tarjeta, marque este requisito como No aplicable y llene el Anexo C: Explicación de los Requisitos Señalados como No Aplicable.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito 11: Poner a Prueba Regularmente la Seguridad de los Sistemas y de las Redes

***Nota**: Para el SAQ A, el Requisito 11 se aplica a los servidores de comerciante con una página web que 1) redirigen a los clientes del sitio web comercial a un TPSP/procesador de pagos para el procesamiento de pagos (por ejemplo, con una redirección de URL) o 2) incluyen una Página/formulario de pago integrado del TPSP/procesador de pago (por ejemplo, uno o más marcos en línea o iframes).*

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
11.3 Las vulnerabilidades externas e internas se identifican, se priorizan y se abordan periódicamente.						
11.3.2	Los escaneos externos de vulnerabilidad se realizan de la siguiente manera: • Al menos una vez cada tres meses. • Por parte de un proveedor de Escaneo Aprobado por PCI SSC (ASV). • Las vulnerabilidades se resuelven y se cumple con los requisitos de la *Guía del Programa ASV.* • Se realizan nuevos escaneos según sea necesario para confirmar que las vulnerabilidades se han resuelto de acuerdo con los requisitos de la Guía del Programa ASV escaneos aprobados.	• Evalúe los reportes de escaneos ASV.	☐	☐	☐	☐
	Notas de Aplicabilidad Para el cumplimiento inicial PCI DSS con respecto a este requisito, no es necesario que se completen cuatro escaneos aprobados en un plazo de 12 meses si el asesor verifica que: 1) el resultado del escaneo más reciente fue un escaneo satisfactorio, 2) la entidad ha documentado políticas y procedimientos que requieren escaneos al menos una vez cada tres meses, y 3) las vulnerabilidades observadas en los resultados del escaneo se han corregido como se muestra en un re-escaneo. Sin embargo, durante los años siguientes después de la evaluación inicial de PCI DSS, deben haberse realizado escaneos aprobados al menos cada tres meses. *(continuación)*					

♦ *Consulte la sección "Respuestas a los Requisitos" (página vii) para obtener información sobre estas opciones de respuesta.*

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
	Las herramientas de escaneo de ASV pueden escanear una amplia gama de tipos y topologías de redes. Cualquier detalle sobre el entorno de destino (por ejemplo, distribuidores de carga, proveedores externos, ISP, configuraciones específicas, protocolos en uso, interferencia de escaneo) debe resolverse entre el ASV y el cliente de escaneo. Consulte la *Guía del Programa ASV* publicada en el sitio web PCI SCC para conocer las responsabilidades del cliente de escaneo, la preparación del escaneo, etc.					
11.3.2.1	Los escaneos externos se realizan después de cualquier cambio significativo de la siguiente manera: • Se resuelven las vulnerabilidades calificadas con 4.0 o más por CVSS. • Los re-escaneos se realizan según sea necesario. • Los escaneos son realizados por personal calificado con la independencia organizacional del probador (no se requiere que sea un QSA o ASV).	• Evalúe la documentación de control de cambios. • Entreviste al personal. • Evalúe los informes de escaneo externo y, en su caso, los informes de re-escaneo.	☐	☐	☐	☐

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Mantener una Política de Protección Informática

Requisito 12: Respaldar la Seguridad de la Información con Políticas y Programas Organizacionales

***Nota**: El Requisito 12 especifica que las empresas tengan políticas de seguridad de la información para su personal, pero estas políticas pueden ser tan simples o complejas como sea necesario para el tamaño y la complejidad de las operaciones del comerciante. El documento con las políticas debe entregarse a todo el personal para que sean conscientes de sus responsabilidades a la hora de proteger los terminales de pago, cualquier documento en papel con datos del tarjetahabiente y/o datos de autenticación sensibles etc. Si una empresa no tiene empleados, se espera que el comerciante entienda y reconozca su responsabilidad con la seguridad dentro de sus tiendas.*

Requisito de PCI DSS		Pruebas Previstas	Respuesta ♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
12.8 Gestión del riesgo de los activos de información asociados a las relaciones con proveedores de servicios externos (TPSP).						
12.8.1	Se mantiene una lista de todos los proveedores de servicios de terceros (TPSP) con los que se comparten datos del titular de la tarjeta o que podrían afectar a la seguridad de los datos del titular de la tarjeta, incluyendo una descripción para cada uno de los servicios prestados.	• Evalúe las políticas y procedimientos. • Evalúe la lista de TPSP.	☐	☐	☐	☐
	Notas de Aplicabilidad El uso de un TPSP que cumpla con PCI DSS no hace que una entidad esté en cumplimiento con PCI DSS, ni elimina la responsabilidad de la entidad por su propio cumplimiento PCI DSS.					

♦ *Consulte la sección "Respuestas a los Requisitos" (página vii) para obtener información sobre estas opciones de respuesta.*

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta ♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
12.8.2	Se mantienen acuerdos escritos con los TPSP de la siguiente manera: • Se mantienen acuerdos escritos con todos los TPSP con los que se comparten datos del titular de la tarjeta o que podrían afectar la seguridad del CDE. • Los acuerdos escritos incluyen el reconocimiento por parte de los TPSP de que los TPSP son responsables por la seguridad de los datos del titular de la tarjeta que los TPSP poseen o almacenan, procesan o transmiten en nombre de la entidad, o en la medida en que puedan afectar a la seguridad de los datos tarjetahabiente o datos de autenticación sensibles de la entidad.	• Evalúe las políticas y procedimientos. • Evalúe los acuerdos escritos con los TPSP.	☐	☐	☐	☐
	Notas de Aplicabilidad La redacción exacta de un acuerdo dependerá de los detalles del servicio que se esté proporcionando y de las responsabilidades asignadas a cada parte. El acuerdo no tiene que incluir la redacción exacta proporcionado en este requisito. El reconocimiento por escrito del TPSP es una confirmación que establece que el TPSP es responsable de la seguridad de los datos de cuenta que pueda almacenar, procesar o transmitir en nombre del cliente o en la medida en que el TPSP pueda afectar la seguridad de los datos tarjetahabiente o datos de autenticación sensibles La evidencia de que un TPSP cumple con los requisitos de PCI DSS no es lo mismo que el reconocimiento por escrito especificado en este requisito. Por ejemplo, una Certificación de Cumplimiento (AOC) de PCI DSS, una declaración en el sitio web de una empresa, una declaración de políticas, una matriz de responsabilidades u otra evidencia que no esté incluida en un acuerdo escrito no es un reconocimiento por escrito.					
12.8.3	Se implementa un proceso establecido para contratar a los TPSP, incluyendo la debida diligencia antes de la contratación.	• Evalúe las políticas y procedimientos. • Evalúe la evidencia. • Entreviste al personal responsable.	☐	☐	☐	☐

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta ♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
12.8.4	Se implementa un programa para monitorear el estado de conformidad PCI DSS de los TPSP al menos una vez cada 12 meses.	• Evalúe las políticas y procedimientos. • Evalúe la documentación. • Entreviste al personal responsable.	☐	☐	☐	☐
	Notas de Aplicabilidad Cuando una entidad tiene un acuerdo con un TPSP para cumplir con los Requisitos de PCI DSS en nombre de la entidad (por ejemplo, a través de un servicio de firewall), la entidad debe trabajar con el TPSP para asegurarse de que se cumplan los Requisitos de PCI DSS aplicables. Si el TPSP no cumple con los Requisitos de PCI DSS aplicables, entonces, esos requisitos también están “no implementado” para la entidad.					
12.8.5	Se mantiene información sobre qué requisitos de PCI DSS gestiona cada TPSP, cuáles gestiona la entidad y cualquiera que se comparta entre el TPSP y la entidad.	• Evalúe las políticas y procedimientos. • Evalúe la documentación • Entreviste al personal responsable.	☐	☐	☐	☐

Guía para llenar el SAQ:

La selección de cualquiera de las respuestas Implementado para los requisitos de 12.8.1 a 12.8.5 significa que el comerciante tiene una lista de proveedores de servicios con los que comparte datos del titular de la tarjeta y tiene acuerdos con ellos, o que podrían afectar la seguridad del entorno de datos de tarjetahabiente del comerciante. Por ejemplo, estos acuerdos serían aplicables si una empresa utiliza un proveedor de conservación de documentos para almacenar documentos en papel que incluyan datos del titular de la tarjeta o si un proveedor del comerciante ingresa a los sistemas del comerciante de forma remota para realizar un mantenimiento.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta ♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
12.10 Los incidentes de seguridad sospechosos y confirmados que podrían afectar al CDE se responden de inmediato.						
12.10.1	Existe un plan de respuesta a incidentes y está listo para activarse en caso de sospecha o confirmación de un incidente de seguridad. El plan incluye, pero no se limita a: • Funciones, responsabilidades y estrategias de comunicación y contacto en caso de sospecha o confirmación de un incidente de seguridad, incluyendo la notificación de marcas de pago y adquirentes, como mínimo. • Procedimientos de respuesta a incidentes con actividades específicas de contención y mitigación para diferentes tipos de incidentes. • Procedimientos de recuperación y continuidad del negocio. • Procesos de respaldo de datos. • Análisis de requisitos legales para reportar situaciones comprometidas. • Cobertura y respuestas de todos los componentes críticos del sistema. • Referencia o inclusión de procedimientos de respuesta a incidentes de las marcas de pago.	• Evalúe el plan de respuesta a incidentes. • Entreviste al personal. • Evalúe la documentación de los incidentes reportados anteriormente.	☐	☐	☐	☐

Guía para llenar el SAQ:

La selección de cualquiera de las respuestas Implementado para el Requisito 12.10.1 significa que el comerciante tiene un plan documentado de respuesta a incidencias y escalada que puede usarse para emergencias, y que es coherente el tamaño y la complejidad de las operaciones del comerciante. Por ejemplo, un plan de este tipo podría ser un simple documento colgado en la oficina que enumere a quién llamar en caso de diversas situaciones, con una revisión anual para confirmar que sigue siendo preciso, pero podría extenderse hasta un plan completo de respuesta a incidentes que incluya instalaciones de reserva "hotsite" y pruebas anuales exhaustivas. Este plan debe estar a disposición de todo el personal como recurso en caso de emergencia.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Anexo A: Requisitos Adicionales de PCI DSS

Anexo A1: Requisitos Adicionales de PCI DSS para Proveedores de Servicios Multiusuario

Este Anexo no se utiliza para las evaluaciones comerciales.

Anexo A2: Requisitos Adicionales de PCI DSS Para Entidades que Utilizan SSL /Primeras Versiones de TLS para Conexiones de Terminal POS POI Presencial con Tarjetas

Este Anexo no se utiliza para evaluaciones comerciales del SAQ A.

Anexo A3: Validación Suplementaria de Entidades Designadas (DESV)

Este Anexo se aplica solo a las entidades designadas por una marca de pago o adquirente que requieren una validación adicional de los Requisitos de PCI DSS vigentes. Las entidades que deban validar este Anexo deben utilizar la Plantilla de Informes Complementarios DESV y la Certificación de Conformidad complementaria para la presentación de informes y consultar con la marca de pago y/o el adquirente correspondiente para los procedimientos de presentación.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Anexo B: Ficha de Control Compensatorio

Este Anexo debe completarse para definir los controles compensatorios para cualquier requisito en el que se haya seleccionado Implementado con CCW.

Nota: *Sólo las entidades que tengan limitaciones tecnológicas o empresariales legítimas y documentadas pueden considerar el uso de controles compensatorios para lograr el cumplimiento.*

Refiérase a los Anexos B y C del PCI DSS para más información acerca de los controles compensatorios y orientación sobre cómo llenar esta hoja.

Número de Requisito y Definición:

	Información Requerida	Explicación
1. Restricciones	Documente las limitaciones técnicas o empresariales legítimas que impiden la conformidad con el requisito original.	
2. Definición de los Controles Compensatorios	Defina los controles compensatorios: explique cómo abordan los objetivos del control original y el aumento del riesgo si lo hay.	
3. Objetivo	Defina el objetivo del control original.	
	Identifique el objetivo que cumple el control compensatorio. ***Nota:*** *Este puede ser, pero no es obligatorio, el Objetivo del Enfoque Personalizado indicado para este requisito en PCI DSS.*	
4. Riesgo Identificado	Identifique cualquier riesgo adicional que suponga la falta del control original.	
5. Validación de los Controles Compensatorios	Defina cómo se validaron y comprobaron los controles compensatorios.	
6. Mantenimiento	Defina los procesos y controles establecidos para mantener los controles compensatorios.	

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Anexo C: Explicación de los Requisitos Señalados como No Aplicable

Este Anexo debe llenarse para cada requisito en el que se haya seleccionado No Aplicable.

Requisito	Razón por la cual el Requisito es No Aplicable
Ejemplo:	
Requisito 3.5.1	*Los datos del titular de la tarjeta nunca se almacenan electrónicamente*

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Anexo D: Explicación de los Requisitos Señalados como No Probado

Este Anexo no se utiliza para las evaluaciones de comerciantes SAQ A.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Sección 3: Detalles de Validación y Certificación

Parte 3. Validación PCI DSS

Parte 3. Validación PCI DSS

Esta AOC se basa en los resultados anotados en el SAQ A (Sección 2), con fecha (Fecha de finalización de la autoevaluación *DD-MM-AAAA* **).**

Sobre la base de los resultados documentados en el SAQ A indicado anteriormente, cada firmante identificado en cualquiera de las Partes 3b–3d, según corresponda, afirma el siguiente estado de conformidad para el comerciante identificado en la Parte 2 de este documento.

Seleccione uno:

☐	**En Conformidad:** Todas las secciones del PCI DSS SAQ están completas y todos los requisitos están marcados como 1) Implementado 2) Implementado con CCW, o 3) No Aplicable, lo que resulta en una calificación general de **EN CONFORMIDAD**; por lo tanto *(Nombre del Comerciante)* ha demostrado estar en conformidad con todos los Requisitos de PCI DSS incluidos en este SAQ.
☐	**No Conformidad:** No se han completado todas las secciones del PCI DSS SAQ, o uno, o más requisitos están marcados como No implementados, lo que resultada en una calificación general de **NO CONFORMIDAD**, por lo que *(Nombre del Comerciante)* no ha demostrado estar en conformidad con los Requisitos de PCI DSS incluidos en este SAQ. **Fecha Límite** para estar en Conformidad: *DD-MM-AAAA* El comerciante que envíe este formulario mostrando un estado de No-Conformidad podría tener que proveer un Plan de Acción como aparece en la Parte 4 de este documento. Confirme con la entidad a la que se presentará este AOC *antes de completar la Parte 4.*
☐	**Conforme pero con una excepción legal:** Uno o más de los requisitos evaluados en el PCI DSS SAQ están marcados como No Implementados debido a una restricción legal que impide que se cumpla con el requisito y todos los demás requisitos están marcados como 1) Implementado, 2) Implementado con CCW, o 3) No Aplicable, lo que da como resultado una calificación general de **EN CONFORMIDAD PERO CON EXCEPCIÓN LEGAL;** por lo tanto, *(Nombre del Comerciante)* ha demostrado estar en conformidad con todos los Requisitos de PCI DSS incluidos en este SAQ, excepto los señalados como No Implementados debido a restricciones legales. Esta opción requiere una revisión adicional por parte de la entidad a la que se presentará este AOC. *Si la selecciona, llene lo siguiente:*

Requisito Concerniente	Detalles de cómo la restricción legal impide que se cumpla con el requisito

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 3a. Reconocimiento del Comerciante	
El signatario confirma: ***(Seleccione todos lo que aplican)***	
☐	El Cuestionario de Autoevaluación PCI DSS A, Versión *4.0.1,* ha sido completado de acuerdo con las instrucciones que en el figuran.
☐	Toda la información contenida en el cuestionario de autoevaluación SAQ y en esta declaración representan fielmente los resultados de la evaluación del comerciante en todos los aspectos materiales.
☐	Los controles PCI DSS se mantendrán en todo momento, según corresponda al entorno del comerciante.

Parte 3b. Declaración del Comerciante	
Firma del Ejecutivo del Comerciante ↑	*Fecha: DD-MM-AAAA*
Nombre del Ejecutivo del Comerciante:	*Título:*

Parte 3c. Declaración del Asesor de Seguridad Calificado (QSA)	
Si un QSA ha participado o asistido en esta evaluación, indique la función que desempeñó:	☐ El QSA realizó los procedimientos de prueba.
	☐ El QSA prestó otro tipo de asistencia. Si ha seleccionado, describa todas las funciones desempeñadas:

Firma del QSA principal ↑	*Fecha: DD-MM-AAAA*
Nombre del QSA principal:	

Firma del Funcionario Debidamente Autorizado de la Compañía QSA ↑	*Fecha: DD-MM-AAAA*
Nombre del Funcionario Debidamente Autorizado:	*Compañía QSA:*

Parte 3d. Participación del Asesor de Seguridad Interna (ISA) del PCI SSC	
Si un ISA ha participado o ha prestado asistencia en esta Evaluación, indique la función desempeñada:	☐ El ISA realizó los procedimientos de prueba.
	☐ El ISA prestó otro tipo de asistencia. Si ha seleccionado, describa todas las funciones desempeñadas:

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 4. Plan de Acción para Requisitos de No Conformidad

Sólo complete la Parte 4 si es solicitado por la entidad a la que se va a presentar este AOC, y sólo si la Evaluación presenta resultados de No-Conformidad señalados en la Sección 3.

Si se le pide que llene esta sección, seleccione la respuesta apropiada para "En Conformidad con los requisitos de PCI DSS" para cada uno de los requisitos siguientes. Para cualquier respuesta "No", incluya la fecha en la que el comerciante espera poder estar en conformidad con el requisito y una breve descripción de las medidas que se están implementando para estar en conformidad.

Requisito de PCI DSS*	**Descripción del Requisito**	**Cumple con los Requisitos de PCI DSS** (Seleccione Uno)		**Rehabilitación Fecha y Acciones** (Si selecciona "NO" para cualquier Requisito)
		SÍ	**NO**	
2	Aplicar configuraciones seguras a todos los componentes del sistema	☐	☐	
3	Proteger los datos del titular de la tarjeta almacenados	☐	☐	
6	Desarrollar y mantener sistemas y softwares seguros	☐	☐	
8	Identificar a los usuarios y autenticar el acceso a los componentes del sistema	☐	☐	
9	Restringir el acceso físico a los datos de tarjetahabiente	☐	☐	
11	Poner a prueba regularmente la seguridad de los sistemas y de las redes	☐	☐	
12	Respaldar la seguridad de la información con políticas y programas organizacionales	☐	☐	

** Los Requisitos de PCI DSS indicados anteriormente se refieren a los requisitos de la Sección 2 de este SAQ.*

Nota: *El PCI Security Standards Council es un organismo de normas global que proporciona recursos para profesionales de la seguridad de los pagos que son desarrollados en colaboración con nuestra comunidad de partes interesadas. Nuestros materiales son aceptados en numerosos programas de cumplimiento en todo el mundo. Consulte con su organización de cumplimiento individual para asegurarse de que este formulario sea aceptado en su programa. Para obtener más información sobre PCI SSC y nuestra comunidad de partes interesadas, visite:* https://www.pcisecuritystandards.org/about_us/.

© 2006-2025 PCI Security Standards Council, LLC. Todos los Derechos Reservados.